

SE

S

V

서

KIS

물레

증 가

현 · QA

집 취약점 시

문제은행 · 검

부터 설계 · 구

웹 보안 (OWASP)

ase Serverless

PWA · i18n



<https://vuln-sim.web.ap>

제작 황병주 (byungjoo hwang) · mibbeuda@gmail.com

기간 2025.12 ~ 2026.07 (약 7개월, 189 commits) · 형태 개인 프로젝트 (풀스택 단독)

"취약점을 체험하고, 취약 코드를 직접 진단하며, 안전한 코드로 고치는 것까지 한 곳에서."
소프트웨어 보안약점 진단원·개발자를 대상으로, 이론 암기에 그치지 않고 실제 공격 시뮬레이션과 코드 레벨 진단을 반복 훈련할 수 있도록 설계한 학습 플랫폼입니다.

372

HTML 페이지

60

취약점 시뮬레이터

49

KISA 보안약점 (CWE)

720+

학습 문항

98/98

SAST 자가검증 통과

2

언어 지원 (KO/EN)

189

Git 커밋

0원

운영비 (무과금 설계)

해결하려는 문제

- 보안약점 학습이 개념·암기 위주로 흘러 실제 코드 진단력으로 이어지지 않음
- 공격을 안전하게 체험할 실습 환경이 부족
- 진단원 시험(KISA 49개 약점)에 맞춘 통합 훈련 도구 부재

대상 사용자

- SW 보안약점 진단원 지망·실무자
- 시큐어코딩을 학습하는 개발자
- 보안 교육 강사·수강생 (강의실·수료증 기능)

학습 사이클 (설계 철학)

체험 → 진단 → 수정 → 검증의 4단계 루프를 모든 콘텐츠에 일관 적용. 공격 시뮬레이션으로 원리를 체감하고, 취약 코드를 정적분석으로 짚고, 안전 코드로 고친 뒤, 도구가 "깨끗함"을 확인해줄 때까지 반복합니다.

차별점

- 브라우저에서 실행되는 SAST — 서버 없이 실시간 코드 진단·채점
- 정탐/오탐 0 자가검증된 룰셋(98/98)
- KISA 49약점 ↔ CWE ↔ 시뮬레이터 완전 매핑
- 완전 무과금 서버리스 아키텍처로 상시 무료 운영

Frontend Vanilla JS (ES Modules), HTML5, CSS3, 반응형 · 다크테마

Platform Firebase Hosting (정적, 무과금 Spark)

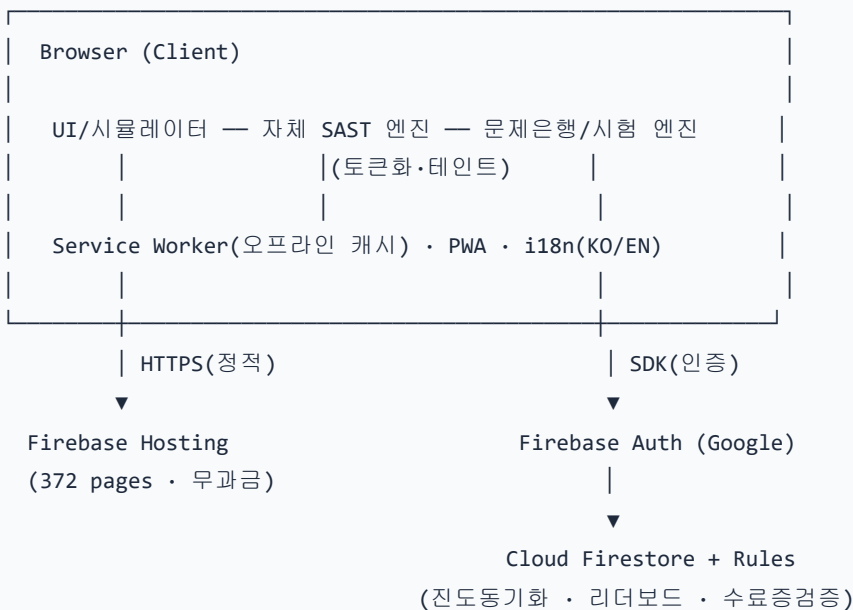
Auth / DB Firebase Authentication, Cloud Firestore (+보안 규칙)

Static Analysis 자체 SAST 엔진(JS) · Python 버그 파인더(패턴 룰셋)

PWA Service Worker(오프라인), Web App Manifest, 설치형

Tooling Git, Firebase CLI, Node 빌드 스크립트, Python

서버리스 · 무과금 설계 — 백엔드 서버 없이 정적 호스팅 + 클라이언트 연산 + Firestore만으로 인증·동기화·리더보드·수료증 검증을 구현. Cloud Functions를 쓰지 않아 **운영비 0원**으로 상시 서비스가 가능하도록 아키텍처를 제약 조건으로 삼아 설계했습니다.



보안 · 신뢰성 설계

- Firestore **보안 규칙**으로 본인 문서만 쓰기, 콘텐츠는 로그인자만 읽기
- 수료증 **불변(create-only)** + SHA-256 해시로 위·변조 방지
- HTTP 보안 헤더(CSP · X-Frame-Options · nosniff 등) 적용



엔지니어링 방식

- 콘텐츠 파이프라인 **자동 생성·병합**(Node 빌드 스크립트)
- 룰셋 단일 소스(rules.json) → JS-Python 양쪽 재사용
- **자가검증(self-test)**으로 회귀 방지 (정탐/오탐 0 유지)

**취약점 시뮬레이터 (60종)**

Burp-style DAST

SQL Injection · XSS · SSRF · XXE · 파일 업로드 등 웹 공격을 브라우저에서 **안전하게 재현**. 실제 요청/응답 흐름과 페이로드를 조작하며 취약점의 동작 원리를 체감하도록 구성.

SQLi

XSS

SSRF

XXE

Path Traversal

CSRF

OS Command

**Secure Code Lab — 취약/안전 코드 49쌍**

KISA 49 · CWE

KISA 구현단계 **49개** 보안약점마다 취약 코드 ↔ 안전 코드 쌍(Java 44 · C 5)과 설명을 제공. 브라우저에서 실행되는 **버그 파인더**가 취약 라인을 짚고, 안전 코드는 "탐지 없음"을 보여줌. 내 코드 붙여넣기 스캔도 지원.

- Python CLI 버그 파인더 + 오프라인 실습 키트(ZIP) 동시 제공
- 단일 룰셋(위험 싱크 + 완화 지표) → **자가검증 98/98, 정탐·오탐 0**

입력검증 17

보안기능 16

시간·상태 2

에러처리 3

코드오류 5

캡슐화 4

API오용 2

**클라이언트 SAST 엔진**

Java·Python **토큰화 및 테인트 추적** 기반 정적분석 엔진을 자체 구현. 서버 없이 브라우저에서 코드의 위험 흐름을 판정합니다.

**Code-Fix Lab**

취약 코드를 직접 수정하면 클라이언트 SAST가 **실시간 자동 채점**. "고쳐서 통과시키기" 방식으로 조치 역량을 훈련합니다.

 적응형 문제은행 & 시험

객관식 319 · 이론 311 · 실전 진단 90 = **720+** 문항
과 개념 카드 49. 오답 CWE에 맞춰 문제를 재구성하
는 **CWE 적응형 시험** 제공.

객관식 319

이론 311

실전 90

 검증 가능한 수료증

SHA-256 해시로 서명한 수료증을 Firestore에 등록,
별도 `verify` 페이지에서 제3자가 진위를 검증. 위·
변조 불가.

 AI 보안 튜터

사용자의 API 키(BYO-Key)로 Claude와 대화하는 소
크라테스식 튜터. 키는 서버로 전송되지 않고 브라우
저에만 보관.

 실제 침해사고 학습

Log4Shell · Heartbleed 등 실제 사고를 **CWE ↔ 시뮬
레이터**로 연결해 "사고에서 배우는 약점"으로 재구
성.

 PWA · 오프라인

Service Worker로 **오프라인 이용·설치형 앱** 지원. 네
트워크 없이도 학습 지속.

 다국어 · 클라우드 동기화

사이트 전역 **한/영 토글**, 로그인 시 학습 진도를 기기
간 자동 동기화.

 실전형 학습 도구 모음

게임화된 반복 학습 도구로 몰입도를 높였습니다.

PR 리뷰 게임

침해 캠페인

스킬 트리

진단 보고서 빌더

오답노트

리더보드/XP

강의실

Web, Linux, DB security with secure coding Learning Hub

실습과 이론을 통한 웹/서버 보안 전문가 양성 플랫폼

NEW · 행정안전부-KISA 기반
개발보안 학습 포털 바로가기
『소프트웨어 개발보안 가이드』 + 『보안악성 진단가이드』 — SDLC 단계별·7대 유형으로 배우는 시큐어코딩

63 WEB VULNS	6 GUIDELINES	17 INPUT VALIDATION	16 SECURITY FEATURES
41 UNIX CONFIG	21 DB SECURITY	43 전자금융 보안	28 WINDOWS 서버

빠른 시작 가이드

- 웹 취약점 실습: 1번 메뉴에서 26가지 공격 기법 학습
- 시큐어 코딩:

인프라 보안 (KISA Guide)

DB Security Simulator
기본 계정, 리스너, 감사 로그 등 핵심 취약점 점검

통합 학습 허브 — 카테고리·진행률 대시보드에서 60여 개 시뮬레이터와 학습 콘텐츠로 진입. 빠른 시작 가이드 · KISA 매핑 제공.

금융 보안 모의해킹 시뮬레이터 Session: 2026-SEC-AUDIT

Target: Core Banking System (Web)
Scenario: SQL Injection & Data Leakage

공격 시뮬레이션 (Red Team)

인터넷 뱅킹 로그인 Verisign Secured

SQL Injection 공격 모드
Authentication Bypass Payload OFF

K-Financial Group
기업자금관리 시스템 (CMS)

이용자 ID
아이디 입력

비밀번호
비밀번호 입력

보안 키퍼드 작동 중 | 마우스 입력 권장

로그인

시큐어 코딩 실습 (Blue Team)

WAS / DB 시스템 로그

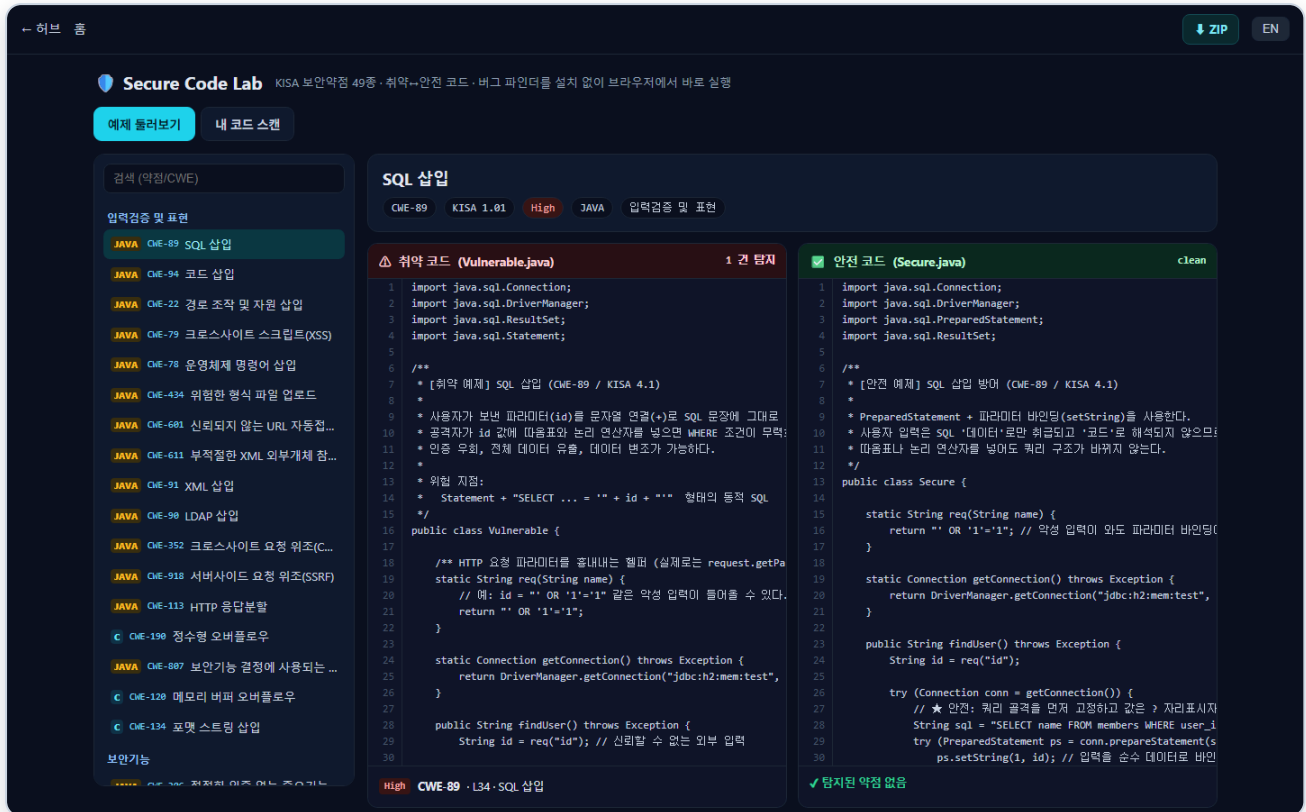
```
[SYSTEM] Web Application Server started.
[SYSTEM] DB Connection Pool initialized.
[INFO] Waiting for user request...
```

컴플라이언스 위반 분석

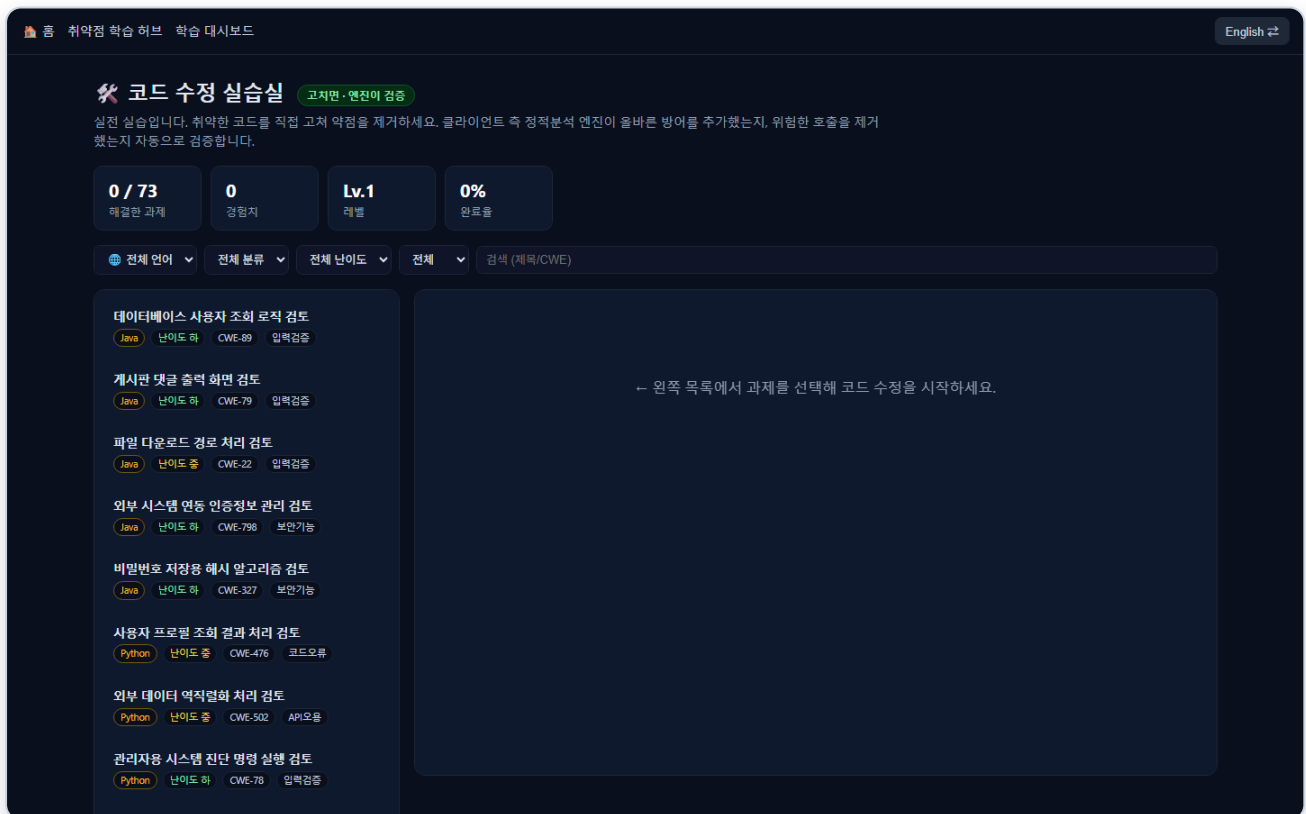
공격 실행 후 분석 결과가 표시됩니다.

이 포털을 오픈으로 설치할 수 있어요. 설치

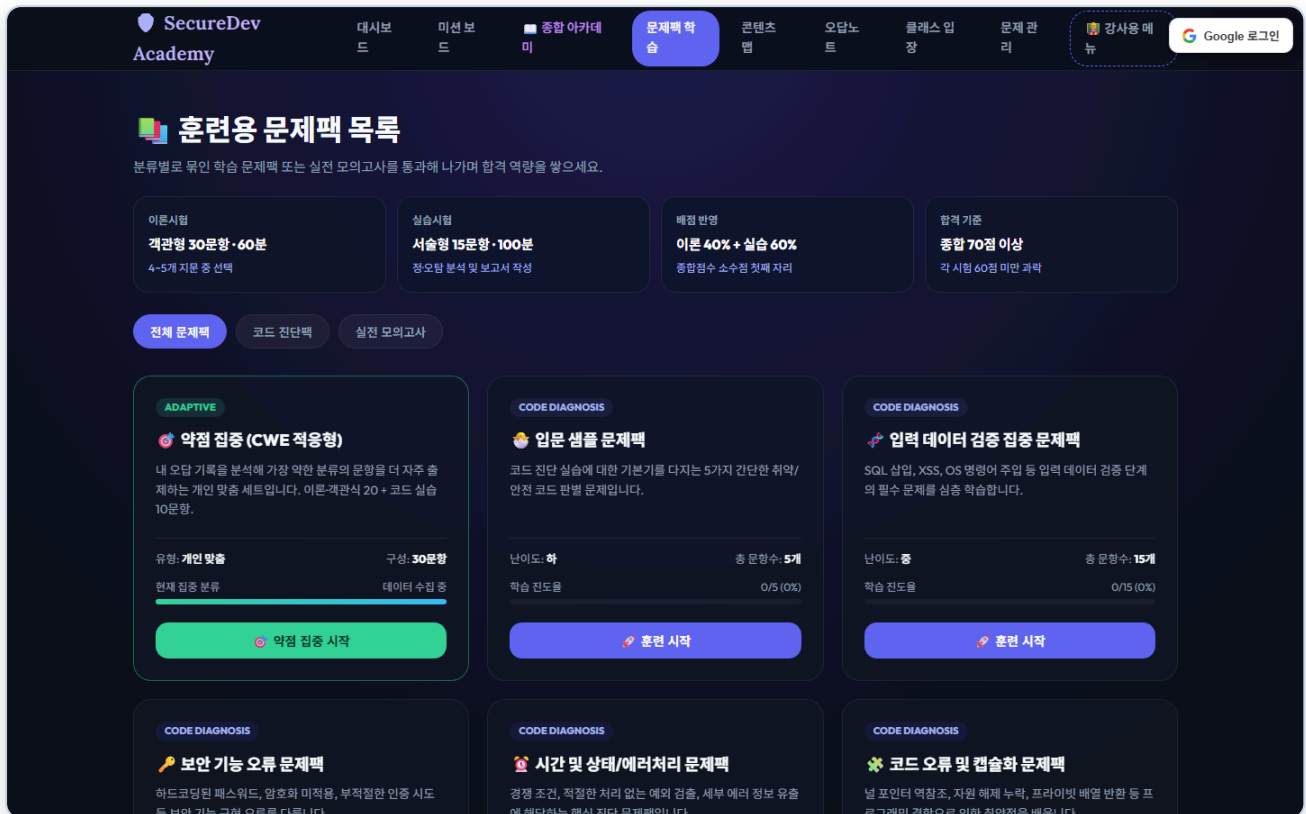
취약점 시뮬레이터 (금융 모의해킹) — Red Team(공격) ↔ Blue Team(시큐어코딩) 구성으로 SQL Injection 등 공격을 안전하게 재현하고 WAS/DB 로그·컴플라이언스 분석을 확인. **Burp-style DAST**



Secure Code Lab — KISA 49악점별 취약 코드 ↔ 안전 코드를 나란히 보여주고, 브라우저에서 실행되는 버그 파인더가 취약 라인을 "1건 탐지", 안전 코드는 "탐지 없음"으로 판정. [In-browser SAST](#)



Code-Fix Lab — 취약 코드(73과제, Java-Python)를 직접 고치면 클라이언트 정적분석 엔진이 방어 추가·위험 제거 여부를 실시간 자동 채점. XP-레벨로 진행 관리.



SecureDev Academy

대시보드 | 미션보드 | 종합아카데미 | 문제은행 | 콘텐츠맵 | 오답노트 | 클래스입장 | 문제관리 | 강사용메뉴 | Google 로그인

훈련용 문제팩 목록

분류별로 묶인 학습 문제팩 또는 실전 모의고사를 통괄해 나가며 합격 역량을 쌓으세요.

이론시험
객관형 30문항·60분
 4~5개 지문 중 선택

실습시험
서술형 15문항·100분
 장오답 분석 및 보고서 작성

배점 반영
이론 40% + 실습 60%
 종합점수 소수점 첫째 자리

합격 기준
종합 70점 이상
 각 시험 60점 미만 과락

전체 문제팩 | 코드 진단팩 | 실전 모의고사

ADAPTIVE
악점 집중 (CWE 적응형)
 내 오답 기록을 분석해 가장 약한 분류의 문항을 더 자주 출제하는 개인 맞춤 세트입니다. 이론·객관식 20 + 코드 실습 10문항.
 유형: 개인 맞춤 | 구성: 30문항
 현재 집중 분류 | 데이터 수집 중
 악점 집중 시작

CODE DIAGNOSIS
입문 샘플 문제팩
 코드 진단 실습에 대한 기본기를 다지는 5가지 간단한 취역/안전 코드 판별 문제입니다.
 난이도: 하 | 총 문항수: 5개
 학습 진도율 | 0/5 (0%)
 훈련 시작

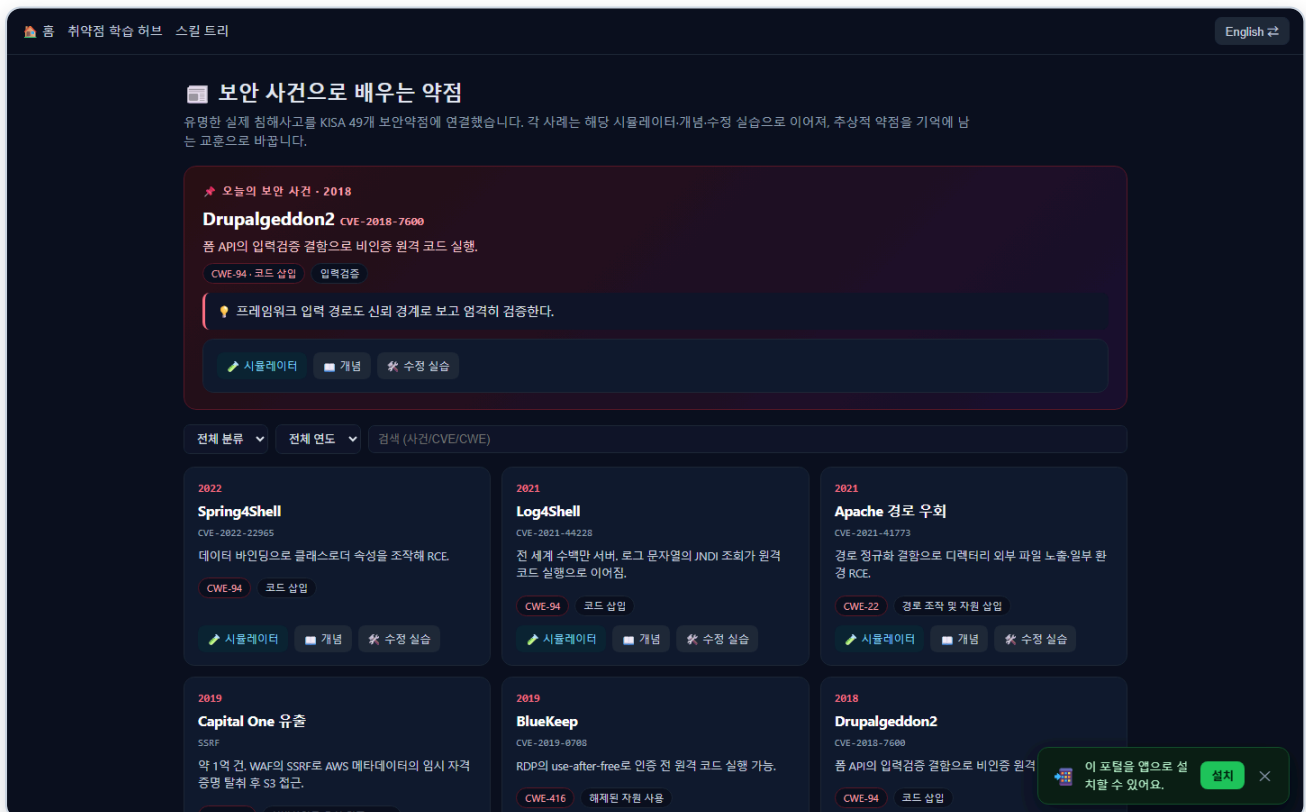
CODE DIAGNOSIS
입력 데이터 검증 집중 문제팩
 SQL 삽입, XSS, OS 명령어 주입 등 입력 데이터 검증 단계의 필수 문제를 심층 학습합니다.
 난이도: 중 | 총 문항수: 15개
 학습 진도율 | 0/15 (0%)
 훈련 시작

CODE DIAGNOSIS
보안 기능 오류 문제팩
 하드코딩된 패스워드, 암호화 미적용, 부적절한 인증 시도 등 보안 기능 구현 오류를 다룹니다.

CODE DIAGNOSIS
시간 및 상태/에러처리 문제팩
 경쟁 조건, 적절한 처리 없는 예외 검증, 세부 에러 정보 유출에 해당하는 핵심 진단 문제팩입니다.

CODE DIAGNOSIS
코드 오류 및 캡슐화 문제팩
 널 포인터 역참조, 자원 해제 누락, 프라이빗 배열 반환 등 프로그래밍 결함으로 인한 취약점을 배웁니다.

훈련용 문제팩 & 적응형 시험 — 객관식·이론·실전 진단 720+ 문항을 CWE 적응형·유형별 문제팩으로 제공. 오답 CWE에 맞춰 시험을 재구성.



취약점 학습 허브 | 스릴 트리 | English

보안 사건으로 배우는 약점

유명한 실제 침해사고를 KISA 49개 보안약점에 연결했습니다. 각 사례는 해당 시나리오·개념·수정 실습으로 이어져, 추상적 약점을 기억에 남는 교훈으로 바꿉니다.

오늘의 보안 사건 · 2018

Drupalgeddon2 CVE-2018-7600

폼 API의 입력검증 결함으로 비인증 원격 코드 실행.

CWE-94 · 코드 삽입 | 입력검증

프레임워크 입력 경로도 신빙 경계로 보고 엄격히 검증한다.

시뮬레이터 | 개념 | 수정 실습

전체 분류 | 전체 연도 | 검색 (사건/CVE/CWE)

2022
Spring4Shell
 CVE-2022-22965
 데이터 바인딩으로 클래스로더 속성을 조작해 RCE.
 CWE-94 | 코드 삽입
 시뮬레이터 | 개념 | 수정 실습

2021
Log4Shell
 CVE-2021-44228
 전 세계 수백만 서버, 로그 문자열의 JNDI 조치가 원격 코드 실행으로 이어짐.
 CWE-94 | 코드 삽입
 시뮬레이터 | 개념 | 수정 실습

2021
Apache 경로 우회
 CVE-2021-41773
 경로 정규화 결함으로 디렉터리 외부 파일 노출·일부 환경 RCE.
 CWE-22 | 경로 조작 및 자원 삽입
 시뮬레이터 | 개념 | 수정 실습

2019
Capital One 유출
 SSRF
 약 1억 건, WAF의 SSRF로 AWS 메타데이터의 임시 자격 증명 탈취 후 S3 접근.
 CWE-918 | 서버사이드 요청 위조(SSRF)

2019
BlueKeep
 CVE-2019-0708
 RDP의 use-after-free로 인증 전 원격 코드 실행 가능.
 CWE-416 | 해제된 자원 사용

2018
Drupalgeddon2
 CVE-2018-7600
 폼 API의 입력검증 결함으로 비인증 원격
 이 포털을 오픈으로 설치할 수 있어요. 설치 ×

실제 침해사고로 배우는 약점 — Log4Shell·Spring4Shell·Capital One 등 실제 사고를 CVE ↔ CWE ↔ 시뮬레이터로 연결해 "사고에서 배우는 약점"으로 재구성.

① 정탐·오탐 0의 자가검증 룰셋

취약/안전 코드 98개 파일에 대해 "취약은 반드시 탐지, 안전은 절대 오탐 안 함"을 자동 검증(self-test)하도록 파이프라인을 설계. 단일 룰셋(rules.json)을 JS·Python 양쪽이 공유하도록 하여 두 도구의 판정이 **바이트 단위로 일치**함을 검증.

② 서버 없는 실시간 코드 진단(브라우저 SAST)

토큰화·테인트 추적 기반 정적분석을 클라이언트에서 수행. "위험 싱크 + 완화 지표" 방식으로 단순 grep 대비 오탐을 크게 낮춰, 서버 비용 없이 실시간 채점/스캔 경험을 구현.

③ 도메인 정확성 검증

NIST SP 800-57의 **RSA↔ECC 키 강도 등가** 등 보안 개념 오류를 리서치로 교정하고, 문항 정답을 다중 검수하여 교육 콘텐츠의 **기술적 정확성**을 확보.

④ 신뢰성 · 장애 격리

클라우드 동기화가 인증 세션을 훼손하던 버그를 **동기화 키 스코프 격리**로 해결. 오프라인 서비스 워커, 로그인 리다이렉트 폴백 등 **실패에 견디는** 클라이언트 설계를 적용.

담당 역할 (1인 풀사이클)

- 제품 기획 · 정보구조 설계
- 프론트엔드 · 정적분석 엔진 **전체 구현**
- 보안 콘텐츠(49약점·720문항) **저작 · QA**
- Firebase 인프라 · 보안규칙 · **배포/운영**

증명된 역량

- 웹 보안 도메인 (**OWASP · CWE · KISA** 진단 기준)
- **정적분석(SAST)** 설계 · 룰 엔지니어링
- 서버리스 · **보안 규칙** 기반 아키텍처
- 대규모 콘텐츠 **자동화 파이프라인** · 품질검증

 **라이브 데모** <https://vuln-sim.web.app> · 시뮬레이터는 로그인 없이 바로 체험 가능

※ 본 문서의 수치는 실제 저장소 기준(2026.07): 372 페이지 · 60 시뮬레이터 · KISA 49 약점 · 720+ 문항 · 189 커밋. 교육용 SAST/버그 파인더는 학습에 최적화된 경량 도구로, 상용 정적분석 도구를 대체하지 않습니다.